A Pedagogical Module for Teaching Fuzzing

Jacob Carney and Dr. Robert Marmorstein (Longwood University)

Introduction

Cyber security refers to a collection of tools and techniques used to defend computer systems, networks, and data from threats, attacks, or unauthorized access. Threats exist in the form of malware, phishing, denial of service attacks, or ransomware.

Due to the inherently complex and vulnerable nature of the Internet, cyber security has become an important field of active research and concern.

Cyber terrorism is the use of information technology to further a political or ideological campaign. [1]

Cyber warfare involves a nation-state penetrating another nation's networks to cause damage or disruption. [1]

Cyber espionage is the use of information technology to obtain information or data without the knowledge or permission of the owner. [1]

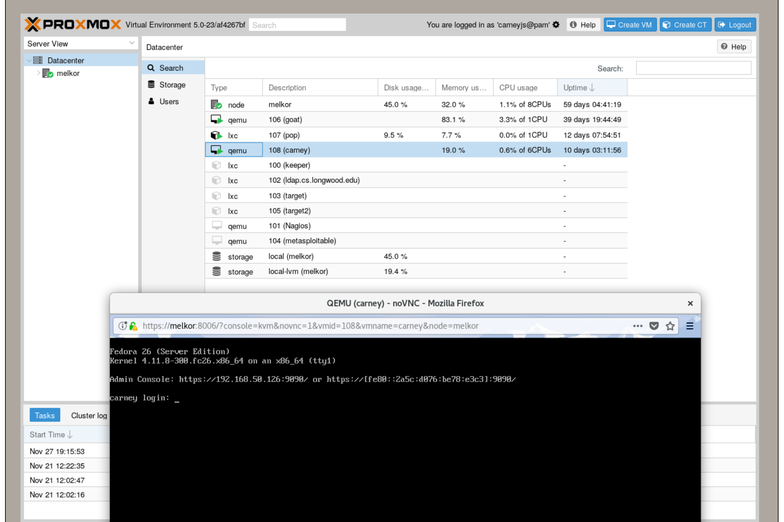

Figure 1. The Proxmox interface

Background

Computer Science 355, Introduction to Computer and Network Security, provides an hands-on overview of many cyber security related topics such as:

- Password Cracking
- Exploiting Software Vulnerabilities
- Cryptography
- Injection and Denial of Service Attacks
- Spoofing Emails
- Setting Up a Linux Firewall

This list is not comprehensive and there are areas where the course is lacking. There are topics that are mentioned in class but without sufficient course material. One such topic is fuzz testing, or fuzzing.

Fuzzing is the process of supplying a program with valid, semi-valid, or random inputs in an attempt to find security loopholes or cause it to behave in an unexpected way. The inputs are then referred to as fuzz.

Software

The list of software used in the course module is:

- zzuf
  - An application input fuzzer used to corrupt or alter random bits in data.
- ImageMagick
  - A program for editing, converting and viewing images.
- Proxmox
  - A Linux distribution designed specifically for remotely hosting virtual machines.
- KASAN
  - A memory error checker and provides a fast solution to finding out of bounds and use after free bugs.
- Syzkaller
  - A kernel fuzzer created by Google that is compatible that is compatible with the Linux and Windows kernels.

Implementation

The module requires students to employs skills they have acquired through the computer science curriculum. Students will write a shell script to handle the creation of malformed files that will be fed to ImageMagick's convert tool.

Since kernel fuzzing is a dangerous penetration testing technique, it should be performed in a sandboxed environment. In this case, the environment is a virtual machine visible only to the Longwood University Advanced Computing Lab. The virtual machine's kernel is recompiled to enable KASAN. The student would create template descriptions for an interface to fuzz.

Future Work

Other modules the class could be expanded to include are:

- Cross-Site Scripting and Cross-Site Request Forgery
- Digital Steganography
- Open Source Intelligence

This module could also be expanded to fuzzing other software.

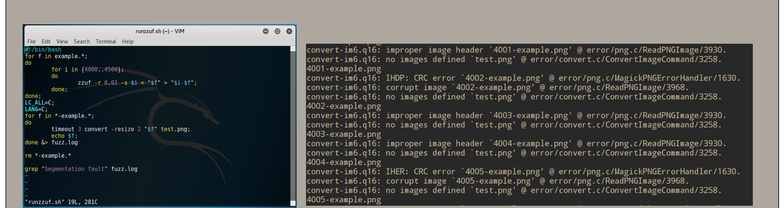

Figure 2. An script for fuzzing with zzuf and sample output

References

[1] "What is Cybersecurity?" paloaltonetworks.com/cyberpedia